

CATALOGGUARD AI

Backend Implementation Rules

Validation Marketplace Backend

Prepared by S P Jyotiranjana Sahoo and Mohammed Yaseen

06 August 2026

1. Backend-wide invariants

Rule ID	Requirement
INV-01	The backend is the authoritative source for permissions, workflow state, validation outcomes and customer readiness.
INV-02	Every seller-owned operation must enforce tenant isolation using the trusted sellerId from the execution context.
INV-03	Every state-changing operation must be idempotent, traceable and auditable.
INV-04	Raw source data must remain immutable; normalization and corrections must create or update canonical records separately.
INV-05	Deterministic validation must run before AI analysis.
INV-06	AI output is advisory and must never directly approve, publish or mutate approved catalog data.
INV-07	Only the customer-visibility gate may mark a product ready for customer use.
INV-08	All timestamps must be stored in UTC and all monetary values must use decimal-safe storage.

2. Execution context

Rule ID	Requirement
CTX-01	Every API request and background job must carry a correlationId.
CTX-02	Every operation must identify actorType as USER, SYSTEM or AI.
CTX-03	USER actions must carry actorUserId and must not carry actorService.
CTX-04	SYSTEM and AI actions must carry actorService and must not carry actorUserId.
CTX-05	User role and sellerId must be derived from the verified session, never from the request body.
CTX-06	Background jobs must receive actor identity from trusted job metadata.
CTX-07	The same correlationId must follow an operation through the API, queue, worker, AI provider and audit log.
CTX-08	Domain services must receive execution context explicitly rather than reading mutable global state.

3. API and controller layer

Rule ID	Requirement
API-01	Route handlers may authenticate, validate input, call domain services and format responses; they must not contain domain logic.
API-02	Path parameters, query parameters, request bodies and required headers must be schema validated.
API-03	Unknown request fields must be rejected instead of silently accepted.
API-04	Responses must use consistent HTTP statuses and stable application error codes.

Rule ID	Requirement
API-05	Passwords, internal prompts, raw storage locations, secrets and sensitive metadata must never be returned to clients.
API-06	All list endpoints must enforce pagination and a maximum page size.
API-07	Login, upload, AI and review endpoints must have appropriate rate limits.
API-08	Every request must receive or generate a correlationId before domain processing begins.
API-09	Large files must be uploaded through private storage or expiring signed-upload URLs.
API-10	API responses must expose only fields required by the calling interface.

4. Authentication

Rule ID	Requirement
AUTH-01	Only users with ACTIVE status may access protected endpoints.
AUTH-02	Disabled users must be rejected even when they present a previously valid session.
AUTH-03	Passwords must be stored only as strong password hashes.
AUTH-04	Authentication errors must not disclose whether an email address exists.
AUTH-05	Session expiry and refresh behavior must be enforced server-side.
AUTH-06	Login, logout, failed authentication and password changes must create audit events.
AUTH-07	Authentication tokens, passwords and secrets must never be written to logs.
AUTH-08	Email addresses must be normalized before uniqueness checks.

5. Authorization and tenant isolation

Rule ID	Requirement
RBAC-01	A SELLER_OPERATOR must have a valid sellerId.
RBAC-02	ADMIN and CATALOG_REVIEWER users should normally have sellerId set to null.
RBAC-03	Every seller-facing database query must filter by the trusted sellerId.
RBAC-04	A seller user must never access another seller's records by submitting a different identifier.
RBAC-05	Catalog reviewers may review catalog records but may not manage sellers or platform configuration.
RBAC-06	Only administrators may manage categories, sellers and platform users.
RBAC-07	Only catalog reviewers and administrators may create REVIEW_DECISION records.
RBAC-08	Authorization must be checked at both the API boundary and the domain-service boundary.
RBAC-09	Seller users may upload, inspect and correct only records belonging to their seller.
RBAC-10	Administrator overrides must require an explicit reason and a dedicated audit event.

6. Feed upload and storage

Rule ID	Requirement
UPL-01	Only CSV, XLSX and JSON feed formats may be accepted by the MVP.
UPL-02	File size, extension, MIME type and basic structure must be validated before processing.
UPL-03	A checksum must be calculated before a feed is queued.
UPL-04	Duplicate checksum submissions must be detected within the same seller scope.
UPL-05	The original uploaded file must be stored privately and treated as immutable.
UPL-06	FEED_UPLOAD must be persisted before its processing job is published.
UPL-07	The initial feed processingStatus must be PENDING.
UPL-08	A failed upload must not leave untracked partial catalog records.
UPL-09	Storage URLs must never be directly customer accessible.
UPL-10	Upload ownership must be recorded through sellerId and uploadedByUserId.

7. Queue and worker processing

Rule ID	Requirement
JOB-01	Large feeds must be parsed and validated by a background worker, not inside a web request.
JOB-02	Every job must have a stable idempotency key.
JOB-03	Executing the same job more than once must not duplicate catalog records or issues.
JOB-04	A job may be acknowledged only after its database changes are committed.
JOB-05	Retries must be bounded and use exponential backoff.
JOB-06	Permanent failures must enter a dead-letter or terminal failure state.
JOB-07	Workers must report heartbeat, progress and last successful checkpoint.
JOB-08	Worker concurrency must be limited to protect MongoDB, storage and the AI provider.
JOB-09	Retrying a job must continue from a safe checkpoint rather than resetting completed rows.
JOB-10	Job cancellation must leave FEED_UPLOAD in an explicit terminal state.
JOB-11	Queue publication must occur only after the corresponding database record is committed.

8. Parsing and normalization

Rule ID	Requirement
PARSE-01	Large feeds must be parsed as streams or controlled batches.
PARSE-02	The original row must be preserved in PRODUCT_SOURCE_DETAIL.rawPayload.
PARSE-03	Each source record must retain its original source row number.
PARSE-04	A malformed row should fail independently unless the complete file is unreadable.
PARSE-05	Whitespace, casing, identifiers, currencies and measurement units must be normalized consistently.
PARSE-06	Normalization must never overwrite rawPayload.
PARSE-07	Field-mapping behavior must have a version identifier.

Rule ID	Requirement
PARSE-08	Unknown source columns may remain in raw data but must not enter the canonical catalog automatically.
PARSE-09	Numeric zero and boolean false must not be treated as missing values.
PARSE-10	Dates and decimal numbers must be parsed explicitly and rejected when ambiguous.
PARSE-11	Row-level parsing failures must include a safe, actionable error summary.

9. Catalog persistence

Rule ID	Requirement
CAT-01	externalProductId must be unique within a seller.
CAT-02	Product detail components must belong to exactly one PRODUCT_RECORD.
CAT-03	Product and component creation must use a MongoDB transaction when multiple collections change together.
CAT-04	Price values must use decimal-safe storage rather than binary floating-point values.
CAT-05	Inventory quantities must be integers and cannot be negative.
CAT-06	Derived values such as availableQuantity must be calculated server-side.
CAT-07	Catalog updates must use optimistic concurrency through currentVersion.
CAT-08	A stale update must return a conflict and must not overwrite a newer product version.
CAT-09	Customer-facing values must never be read directly from raw source payloads.
CAT-10	Every material mutation must update updatedAt and create an audit event.
CAT-11	Component references on PRODUCT_RECORD must always point to records in the same logical product aggregate.

10. Database and repository layer

Rule ID	Requirement
DB-01	Only repository modules may directly access MongoDB collections.
DB-02	Domain services must not contain ad hoc raw database queries.
DB-03	All collections must enforce schema validation for required fields, enums and value ranges.
DB-04	User email must have a normalized unique index.
DB-05	sellerId and externalProductId must have a compound unique index.
DB-06	Feed status and upload time must be indexed for operational queries.
DB-07	Product workflow status must be indexed for review and readiness queries.
DB-08	Open validation issues must be indexed by product, status and severity.
DB-09	Review queue fields must be indexed for status and age ordering.
DB-10	Audit logs must be indexed by entityType, entityId and occurredAt.
DB-11	Unbounded collection scans and unbounded virtual-reference population are prohibited.
DB-12	Queries must use projections to retrieve only required fields.

Rule ID	Requirement
DB-13	Feed-row persistence must use bounded bulk operations.
DB-14	Database migrations must be versioned, repeatable and safe to rerun.

11. Rule-based validation

Rule ID	Requirement
VAL-01	Deterministic rules must run before AI analysis.
VAL-02	Every validation rule must have a stable ruleId and version.
VAL-03	Validation output must include fieldPath, severity, message and detectedValue.
VAL-04	The same rule must not create duplicate open issues for the same product version.
VAL-05	INFO issues are informational and do not block workflow.
VAL-06	WARNING issues recommend review but do not independently block approval.
VAL-07	ERROR issues block approval until resolved or validly waived.
VAL-08	BLOCKER issues prohibit processing or customer visibility until resolved.
VAL-09	Revalidation must resolve obsolete issues or reopen recurring issues.
VAL-10	Validation rules must never approve products directly.
VAL-11	Every validation failure must create a structured VALIDATION_ISSUE.
VAL-12	Rule execution must be deterministic for the same input and rule version.

12. AI processing

Rule ID	Requirement
AI-01	AI may run only for semantic, classification or otherwise ambiguous checks.
AI-02	AI must not replace deterministic validation for required fields, types, ranges or arithmetic checks.
AI-03	AI inputs must be sanitized and limited to catalog data required for the analysis.
AI-04	Personally identifiable information, credentials and secrets must not be sent to the AI provider.
AI-05	AI output must conform to a strict structured response schema.
AI-06	Malformed, incomplete or schema-invalid AI output must be rejected.
AI-07	AI calls must have timeouts and bounded retries.
AI-08	AI_ANALYSIS must store provider, model, promptVersion, inputSnapshot, output and confidence.
AI-09	Low-confidence output must create a review suggestion rather than an automatic correction.
AI-10	AI must never directly mutate approved catalog data.
AI-11	An applied AI suggestion must pass deterministic validation again.
AI-12	AI usage, latency, failures and cost must be attributable to a feed or seller.
AI-13	Internal prompts and provider failures must not be exposed to seller users.

Rule ID	Requirement
AI-14	An AI-generated audit event must use actorType AI and a non-empty actorService.

13. Validation issue lifecycle

Rule ID	Requirement
ISS-01	Every validation issue must belong to a product and seller.
ISS-02	Allowed issue transitions are OPEN to IN_REVIEW, then RESOLVED or WAIVED.
ISS-03	Only reviewers or administrators may waive BLOCKER issues.
ISS-04	Resolution must record resolvedByUserId, resolvedAt and a resolution note.
ISS-05	Resolved issues must not be deleted.
ISS-06	A recurring issue must be reopened or linked to its previous occurrence.
ISS-07	Product issue counts must include unresolved issues only.
ISS-08	Issue deduplication must consider product version, fieldPath and ruleId.
ISS-09	Issue status changes must create audit events.

14. Review workflow

Rule ID	Requirement
REV-01	Review actions must use explicit workflow transitions.
REV-02	A reviewer must see and decide on a specific product version.
REV-03	If the product changes during review, the stale decision must be rejected.
REV-04	Approval is allowed only when no OPEN ERROR or BLOCKER issues remain.
REV-05	Rejection and change-request decisions must include reviewer notes.
REV-06	Decision creation, workflow update and audit creation must occur in one transaction.
REV-07	Review decisions are immutable; later decisions must create new records.
REV-08	Seller users may not approve or waive issues on their own products.
REV-09	Administrator overrides must include a reason and a separate override audit action.
REV-10	The review queue must be paginated and ordered using stable indexed fields.

15. Product workflow state

Rule ID	Requirement
WF-01	The standard progression is DRAFT to VALIDATING to PENDING_REVIEW to APPROVED to READY_FOR_CUSTOMER_USE.
WF-02	VALIDATING may transition to BLOCKED when unresolved blocking issues exist.
WF-03	PENDING_REVIEW may transition to CHANGES_REQUESTED or REJECTED.
WF-04	CHANGES_REQUESTED may return only to VALIDATING after seller correction.

Rule ID	Requirement
WF-05	Clients must not submit a desired workflow status directly.
WF-06	All transitions must be executed by the workflow service.
WF-07	Each transition must record previous state, new state, reason and actor.
WF-08	Seller corrections must trigger revalidation.
WF-09	A rejected product cannot become approved without returning through validation and review.
WF-10	Undefined state transitions must be rejected as conflicts.

16. Audit logging

Rule ID	Requirement
AUD-01	AUDIT_LOG must be append-only.
AUD-02	actorType must be one of USER, SYSTEM or AI.
AUD-03	actorUserId is required when actorType is USER and must be null otherwise.
AUD-04	actorService is required when actorType is SYSTEM or AI and must be null for USER.
AUD-05	Feed uploads and cancellations must create audit events.
AUD-06	Product creation and material modification must create audit events.
AUD-07	Validation completion and AI suggestions must create audit events.
AUD-08	Issue resolution, waiver and reopening must create audit events.
AUD-09	Review decisions, workflow transitions and administrator overrides must create audit events.
AUD-10	User, role, seller-status and category changes must create audit events.
AUD-11	Before and after snapshots must be sanitized.
AUD-12	Passwords, tokens and complete uploaded files must not be stored in audit records.
AUD-13	Audit metadata must include correlationId and may include request or job identifiers.
AUD-14	Normal application services must not update or delete audit events.
AUD-15	The audit event should be committed in the same transaction as the corresponding mutation.

Audit actor constraints

actorType	actorUserId	actorService
USER	Required	Must be null
SYSTEM	Must be null	Required
AI	Must be null	Required

17. Customer-visibility gate

Rule ID	Requirement
GATE-01	A product may be customer-ready only when its workflow status is APPROVED.
GATE-02	The owning seller must have ACTIVE status.
GATE-03	All required catalog fields must be present and valid.
GATE-04	Pricing must be valid and currently effective.
GATE-05	Inventory state must be valid.
GATE-06	The assigned category must be active and assignable.
GATE-07	No unresolved ERROR or BLOCKER issue may exist.
GATE-08	The approved product version must match the latest product version.
GATE-09	Neither the AI service nor the ingestion worker may bypass the gate.
GATE-10	Gate evaluation and readiness-state mutation must be atomic or concurrency protected.

18. Error handling and retries

Rule ID	Requirement
ERR-01	Errors must be categorized as validation, authentication, authorization, conflict, dependency or internal.
ERR-02	Stack traces and internal exception details must not be returned to clients.
ERR-03	Client-safe errors must include a stable error code and correlationId.
ERR-04	Retriable failures must be distinguished from permanent failures.
ERR-05	Schema errors, invalid files and authorization failures must not be retried.
ERR-06	External dependency calls must have explicit timeouts.
ERR-07	Partial batch failures must identify failed rows rather than hiding them.
ERR-08	Unexpected errors must be logged with correlationId, service and operation.
ERR-09	Retry attempts must be bounded and visible in operational metrics.

19. Observability

Rule ID	Requirement
OBS-01	Application logs must be structured.
OBS-02	Every log entry must include correlationId, service and operation when available.
OBS-03	Sensitive product payloads, credentials and tokens must not be logged.
OBS-04	Feed duration, processed rows and rejected rows must be measured.
OBS-05	Queue depth, retry count, dead-letter count and job age must be measured.
OBS-06	Validation issues must be measurable by rule, status and severity.
OBS-07	AI latency, failure rate, usage and cost must be measured.
OBS-08	Review-queue age and backlog must be measured.
OBS-09	Database query latency and slow-query counts must be measured.
OBS-10	Customer-readiness failures must be measurable by reason.

Rule ID	Requirement
OBS-11	Alerts must cover stuck jobs, repeated worker failures and growing review backlogs.

20. Security and privacy

Rule ID	Requirement
SEC-01	Secrets must be supplied through protected environment configuration.
SEC-02	Required environment variables must be validated at startup.
SEC-03	Traffic to databases, storage and external providers must be encrypted in transit.
SEC-04	Private files and sensitive stored values must use encryption at rest where supported.
SEC-05	Rich-text product descriptions must be sanitized before storage or rendering.
SEC-06	Spreadsheet-formula injection must be prevented when exporting CSV or XLSX values.
SEC-07	Storage links must be signed, scoped and short lived.
SEC-08	File access must verify seller ownership.
SEC-09	Cookie-based authentication must use appropriate CSRF protection.
SEC-10	The backend must not fetch arbitrary seller-provided URLs without SSRF protections.
SEC-11	Authentication credentials, provider keys and tokens must not appear in logs or API responses.
SEC-12	Dependencies must be monitored and patched for security vulnerabilities.

21. Performance and scalability

Rule ID	Requirement
PERF-01	Feed rows must be processed in bounded batches.
PERF-02	Bulk writes must be used instead of one database write per row.
PERF-03	Category and validation-rule definitions may be cached for short controlled periods.
PERF-04	Review queues and product lists must be paginated.
PERF-05	List endpoints must not load complete product histories.
PERF-06	Database operations and external calls must have timeouts.
PERF-07	Limits must exist for feed size, row count and concurrent jobs per seller.
PERF-08	AI calls must use controlled concurrency.
PERF-09	Dashboard metrics should use aggregations or cached summaries instead of repeated full scans.
PERF-10	Indexes must be reviewed against actual query patterns before production release.

22. Testing and quality gates

Rule ID	Requirement
TEST-01	Mapping, validation rules and workflow transitions must have unit tests.

Rule ID	Requirement
TEST-02	Repository behavior must have integration tests against MongoDB.
TEST-03	Every role and seller boundary must have authorization tests.
TEST-04	Feed tests must cover malformed files, duplicate files and partial row failures.
TEST-05	Idempotency tests must execute the same job more than once.
TEST-06	AI integration must have contract tests using saved structured responses.
TEST-07	Review workflow tests must cover stale product versions and conflicting decisions.
TEST-08	Transaction tests must verify rollback behavior.
TEST-09	End-to-end tests must cover upload through review and readiness evaluation.
TEST-10	Security tests must prove that one seller cannot access another seller's data.
TEST-11	No release may proceed with failing schema, authorization, workflow or tenant-isolation tests.

23. Configuration, deployment and recovery

Rule ID	Requirement
OPS-01	Application startup must fail fast when required configuration is missing or invalid.
OPS-02	Environment-specific settings must not be hard-coded in application modules.
OPS-03	Database schema and index migrations must run through a controlled deployment step.
OPS-04	Production migrations must have a tested rollback or forward-fix plan.
OPS-05	Feature flags should protect risky AI, validation or workflow changes.
OPS-06	Backups and restoration procedures must be tested before production use.
OPS-07	Queue and worker deployments must support graceful shutdown without losing acknowledged work.
OPS-08	Health checks must distinguish application health from dependency readiness.
OPS-09	Staging must use production-like schemas and workflow configuration without production secrets.
OPS-10	Deployment records must identify application version, migration version and rules version.